



Segurança de Aplicações



SQL Injection

SQL Injection ou injeção SQL é uma vulnerabilidade de segurança web que permite uma ameaça – no geral um criminoso cibernético – interferir nas consultas que um determinado sistema ou aplicação web realiza em seu banco de dados, possibilitando assim a ameaça visualizar dados que normalmente não são capazes de recuperar. Esses dados podem ser, por exemplo: dados de clientes, dados de usuários ou qualquer outro tipo de dados que esteja armazenado no banco de dados.

Dependendo da técnica utilizada de SQL injection a ameaça pode incluir, alterar ou até excluir dados do banco de dados ou comprometer o servidor em que se encontra o sistema/aplicação, causando danos e/ou a negação dos serviços providos pelo sistema/aplicativo impossibilitando que clientes realizar o acesso e consumam, por exemplo, algum produto ou serviço da organização.

Com relação às consequências e impactos, além dos mencionados anteriormente, um ataque do tipo SQL injection pode resultar em acesso não autorizado a dados confidenciais e/ou pessoais/pessoais sensíveis e até promover o vazamento desses dados na Internet, por exemplo. É importante ressaltar que ao longo do tempo, muitas violações, perdas e vazamentos de dados foram resultados de ataques de SQL injection, o que causou a muitas organizações danos à reputação e multas regulatórias.

Para evitar esse tipo de ataque, as equipes de segurança devem realizar o gerenciamento de vulnerabilidades para tratar dos pontos fracos e, em conjunto com os desenvolvedores de sistemas e aplicativos para web implementar consultas

parametrizadas, também conhecidas como instruções preparadas em vez de concatenadas em strings da linguagem SQL.

XSS – CROSS SITE-SCRIPTING

XSS ou Cross Site-Scripting é um tipo de ataque que há exemplo do SQL injection, realiza uma injeção de dados, que no caso são scripts maliciosos em sítios, sistemas e aplicativos web. Esse tipo de ataque ocorre quando a ameaça usa um sistema ou aplicativo web para enviar um script (código de programação) malicioso, no formato em que o navegador de internet, fazendo com o usuário entenda que se trata do sistema ou aplicação verdadeiros.

No geral ataques do tipo XSS são destinados a desviar o usuário para uma página falsa, simulando a página verdadeira e assim possibilitando o criminoso cibernético roubar dados ou informações do usuário, tais como número do cartão de crédito, por exemplo, sem que ele perceba que está em um ambiente totalmente falso.

Os ataques XSS podem ocorrer de 2 maneiras: a primeira é quando os dados entram em um sistema/aplicativo web por meio de uma fonte não confiável e, a segunda é quando os dados são incluídos no conteúdo que é enviado ao usuário que por sua vez não percebe que está recebendo um conteúdo malicioso e mal-intencionado.

As equipes de segurança da informação e segurança cibernética, realizam constantemente análises de vulnerabilidades em seus sistemas e aplicações web, para verificar se eles estão ou não suscetíveis a ataques do tipo XSS, além de testes de intrusão voltados para sistemas e/ou aplicativos web.

Além dessas medidas, as equipes de segurança devem atuar em conjunto com as equipes de desenvolvimento, informando as falhas e solicitando as devidas correções e sempre que necessário recorrer às recomendações fornecidas pela entidade OWASP que veremos a seguir.

OWASP

OWASP é um acrônimo de Open Web Application Security Project ou Projeto Aberto de Segurança para Aplicações Web Abertas. Trata-se de uma entidade sem fins lucrativos formada por diversas organizações privadas e governamentais, entidades relacionadas a segurança cibernética, desenvolvedores, pesquisadores, especialistas em segurança cibernética e demais entusiastas no assunto desenvolvimento de sistemas para a Internet e segurança cibernética, que tem como principal objetivo prover: (a) informações relacionadas ao desenvolvimento seguro de sistemas e aplicações para a Internet; (b) servir como um guia para o desenvolvimento seguro de sistemas e aplicações para a Internet; © prover ferramentas e recursos destinados à segurança cibernética e a segurança de sistemas e aplicações web; (d) promover a comunicação e o debate de novas tecnologias; (e) promover as melhores práticas no desenvolvimento de sistemas e aplicativos web de forma segura; (f) promover a informação e por fim (g) promover programas educacionais de treinamento e conscientização sobre o desenvolvimento de sistemas e aplicativos voltados para a Internet bem como a segurança e proteção deles.

Uma das contribuições mais importantes da fundação OWASP é o projeto Owasp Top 10 que tem como objetivo servir como um documento de referência que descreve as 10 maiores preocupações e ameaças de segurança mais críticas para sistemas e aplicativos voltados para a Internet.

Por fim, outra contribuição muito útil para as equipes de segurança cibernética e desenvolvedores de sistemas web é a ferramenta OWASP-ZAP. Essa ferramenta totalmente open source permite às equipes de segurança cibernética realizar a identificação de vulnerabilidades em sistemas e aplicativos web, bem como orientar quais medidas necessárias à correção dessas vulnerabilidades, além de possibilitar testes de intrusão nesses mesmos sistemas e aplicativos web.

WAF – Web Application Firewall

O WAF (Web Application Firewall) é um novo tipo de firewall desenvolvido para combater ameaças que ultrapassam as capacidades dos firewalls tradicionais (MACHADO, 2014). Esse dispositivo cria uma barreira entre o serviço baseado na web e o restante da Internet, protegendo a aplicação de ações criminosas como manipulação de conteúdo exibido, injeções indevidas em banco de dados SQL e outros tipos de ciberataques (STALLINGS; BROWN, 2017).

A atuação do WAF garante a proteção adequada das redes de diferentes tipos de negócios, auxiliando as equipes de segurança da informação e segurança cibernética no combate às principais ameaças e na continuidade das operações da empresa (SÊMOLA, 2014). O WAF trabalha para impedir a exposição não autorizada de dados em um site ou aplicativo baseado na web (HARRIS, 2004). Nesse contexto, o WAF monitora, filtra e bloqueia automaticamente o tráfego de dados potencialmente maliciosos (TANENBAUM, 2011).

Existem diferentes tipos de WAFs, cada um com suas vantagens e desvantagens (KIM; SOLOMON, 2014). O WAF de Rede, geralmente baseado em hardware, é mais rápido e tem gerenciamento simplificado, mas apresenta custos mais altos de implementação (FREIRE, 2004). O WAF de Host, por outro lado, oferece maior possibilidade de personalização a um custo mais baixo, porém seu gerenciamento pode ser desafiador (LYRA, 2008). Já o WAF na Nuvem, administrado pelos provedores do serviço, é de fácil implantação e oferece uma opção econômica e escalável (FONTES, 2008).

Independentemente do tipo de WAF implementado, é recomendável que a equipe de segurança participe de treinamentos de administração (HARRIS, 2004). Além disso, é importante envolver a equipe de desenvolvimento na tarefa, já que um WAF configurado incorretamente pode afetar negativamente a performance e disponibilidade da aplicação protegida (STALLINGS; BROWN, 2017).

VM ou Virtual Machines

VM (virtual machines) ou máquinas virtuais é uma tecnologia que possibilita a criação de sistemas computacionais completos por meio da virtualização. Ou seja, é um sistema projetado para criar e executar de forma virtual um sistema computacional, incluindo todo o conjunto de hardware e sistema operacional.

Uma VM consiste em ter um computador ou servidor que forneça todos os recursos necessários de hardware para a criação de uma máquina virtual. Esse equipamento é conhecido como máquina hospedeira e, cada máquina virtual criada por ele é conhecida como máquina hóspede ou simplesmente hóspede.

Para gerenciar todo esse conceito de hospedeiro e hóspede, existe um sistema específico denominado de hipervisor, que tem como objetivo particionar os recursos de hardware (processamento, memória e armazenamento) de uma máquina hospedeira para os hóspedes, de forma isolada. Ou seja, cada máquina hóspede recebe uma porção dos recursos de hardware da máquina hospedeira, sem que um hóspede incomode o outro.

Este tipo de recursos é utilizado na segurança da informação e segurança cibernética como uma solução de recuperação de desastres e continuidade de negócios. Isto porque, as equipes de segurança criam cópias de servidores críticos no formato de máquinas virtuais e em caso de incidentes indesejados de segurança, colocam essas máquinas virtuais em produção temporariamente até que o servidor principal volte a operar normalmente.

Sandbox

Sandbox ou conhecido também como caixa de areia é um recurso utilizado por desenvolvedores e equipes de segurança para realizar testes isolados, permitindo assim que usuários realizem suas atividades de forma isolada ao sistema ou aplicação principal. O sandbox é no geral utilizado para que as equipes de desenvolvimento e segurança realizem a homologação de um sistema ou de um recurso antes mesmo que este entre em produção e, com isso, possam validar o mesmo.

Outro propósito do sandbox é a execução de códigos maliciosos com segurança. Ou seja, as equipes de segurança da informação ou segurança cibernética, constroem um ambiente sandbox e nele executam o código malicioso com o propósito de estudar e conhecer o que aquele código malicioso faz, qual dano ele causa e assim poderem pensar em medidas adequadas de proteção.

É importante ressaltar que à medida que os códigos maliciosos se tornam mais sofisticados, monitorar comportamentos suspeitos para detectar esses códigos maliciosos tornou-se cada vez mais difícil. Isto porque, muitas ameaças nos últimos anos têm utilizado técnicas avançadas de ofuscação que podem evitar a detecção de produtos de ponto final e segurança de rede.

Neste contexto, o sandbox protege a infraestrutura crítica de uma organização contra códigos suspeitos porque ele é executado em um sistema separado. Ele também permite que a TI teste código malicioso em um ambiente de teste isolado para entender como ele funciona, bem como detectar mais rapidamente ataques semelhantes.

Conteúdo Bônus

Complemente seu conhecimento sobre segurança em aplicações web navegando pelo site OWASP. Dica de título para pesquisa:

- Projeto Owasp top 10.

Referência Bibliográfica

FONTES, E. **Praticando a segurança da informação**. Brasport, 2008.

FREIRE, Alexandre. **Sistemas de Firewall e Defesa de Perímetros. Portal Módulo Security, 2004.**

Guide to Intrusion Detection and Prevention Systems (IDPS). Disponível em: <<http://csrc.nist.gov/publications/nistpubs/800-94/SP800-94.pdf>>.

HARRIS, Shon. **CISSP All-in-one, 3. ed.**: Mc Graw Hill, 2004.

KIM, David; SOLOMON, Michael. **Fundamentos de Segurança de Sistemas de Informação** – 1.ed. São Paulo; LTC Exatas Didática, 2014.

LASTRE, H. M. M., ALBAGLI, S. (Org.). **Informação e globalização na era do conhecimento**. Rio de Janeiro: Campus, 1999. 318p.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação**. Rio de Janeiro: Ciência Moderna, 2008.

OWASP. **Cross Site Scripting (XSS)**. Disponível em < <https://owasp.org/www-community/attacks/xss/>>.

MACHADO, Felipe R. Nery. **Segurança da Informação – Princípios e controle de ameaças** – 1.ed. Rio de Janeiro; Editora Érica, 2014.

Microsoft **“TechNect: protocolos de encapsulamento de VPN.”** 2011. (6 de novembro de 2019) <[http://technet.microsoft.com/en-us/library/cc771298\(WS.10\).aspx](http://technet.microsoft.com/en-us/library/cc771298(WS.10).aspx)>.

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva** - 2 ed. São Paulo: Elsevier, 2014.

STALLINGS, W. **Criptografia e Segurança de Redes**. 4 ed. São Paulo: Pearson, 2008.

STALLINGS, Willian; BROWN Lawrie. **Segurança de Computadores – Princípios e Práticas**. 2.ed. São Paulo; Elsevier, 2017.

TANENBAUM, Andrew. S. **Redes de Computadores**. 4ª ed. Rio de Janeiro: Editora Campus (Elsevier), 2011.

Ir para exercício